

Firme e sigilli elettronici

Guida sintetica

Normative e Standard

Area di applicazione

Regolamento (UE) n. 910/2014 (eIDAS)

Quadro giuridico europeo per firme elettroniche, identificazione digitale e servizi fiduciari. Definisce FEA, FEQ, sigilli, marche temporali e QTSP. Garantisce interoperabilità tra Stati membri.

AgID – Linee guida su FEQ e servizi fiduciari

Regole tecniche italiane per firme elettroniche qualificate, certificati, sigilli e validazioni temporali. Stabilisce requisiti per QTSP e formati di firma (PAdES, CAdES, XAdES).

ETSI TS 119 431-1

Policy e requisiti di sicurezza per QTSP che gestiscono dispositivi di firma remoti (remote QSCD). Include SAP/SAM per controllo esclusivo del firmatario e certificazione dei servizi.

CEN EN 419 241-2

Protection Profile per QSCD lato server. Basato su Common Criteria (EAL4+) per garantire protezione delle chiavi e controllo esclusivo tramite SAD. Usato per certificare firme remote qualificate.

Normative e Standard

Glossario acronimi

Regolamento (UE) n. 910/2014 (eIDAS)

eIDAS = electronic IDentification, Authentication and trust Services;

FEA = Firma Elettronica Avanzata;

FEQ = Firma Elettronica Qualificata;

QTSP = Qualified Trust Service Provider

AgID

AgID = Agenzia per l'Italia Digitale

CAD = Codice dell'Amministrazione Digitale

PAdES/CAdES/XAdES = Standard di firma elettronica per PDF,
CMS, XML

ETSI TS 119 431-1

ETSI = European Telecommunications Standards Institute;

QSCD = Qualified Signature Creation Device;

SAP = Signature Activation Protocol;

SAM = Signature Activation Module;

SSAS = Server Signing Application Service

CEN EN 419 241-2

CEN = European Committee for Standardization;

SAD = Signature Activation Data;

EAL4+ = Evaluation Assurance Level 4;

PP = Protection Profile

Firme certificate / 1

Tipologia	Titolare	Owner/ Responsabile	Dove sta la chiave	Autenticazione richiesta	Controllo esclusivo	Casi d'uso
Firma locale con smartcard	Persona fisica	Medico / Professionista	Su smartcard/token USB del firmatario	PIN (più possesso fisico del dispositivo)	Garantito dal dispositivo fisico (QSCD locale)	Firme puntuali in contesti tradizionali o con postazioni fisse
Firma remota classica	Persona fisica	Medico / Professionista	Su HSM/QSCD gestito dal QTSP (cloud o on-prem)	Autenticazione forte per ogni firma: PIN + OTP/SPID/CIE	Tramite meccanismo di Signature Activation (SAP/SAM) per operazione	Firme singole in workflow con intervento umano (contratti, atti)
Firma remota batch	Persona fisica	Medico / Professionista	Su HSM/QSCD del QTSP	Un'unica autenticazione forte per lotto (PIN + OTP/SPID/CIE)	Controllo valido per la sessione/lotto di firma	Firme multiple in un'unica operazione (lotti documentali)
Firma automatica	Persona fisica	Owner applicativo + DPO/Compliance	Su HSM/QSCD del QTSP (cloud o on-prem)	Autenticazione solo iniziale (delega); poi nessun OTP/PIN per ogni firma	La delega è circoscritta ad atti privi di valutazione personale del medico.	Processi massivi/time-critical; integrazioni applicative server-side
Sigillo elettronico qualificato	Persona giuridica (ente/azienda)	IT/Legal dell'Ente	Su HSM/QSCD dell'organizzazione/ QTSP	Gestita dal sistema (non dal singolo individuo)	Controlli di sistema e policy organizzative	Fatture, attestazioni, referti già validati dal workflow, certificazioni di sistema
Firma elettronica qualificata (FEQ)	Persona fisica	Medico / Professionista	Su QSCD (locale con smartcard o remoto su HSM)	Autenticazione forte (varia per modello: PIN; PIN+OTP; SPID/CIE)	Richiesto controllo esclusivo del firmatario (dispositivo o SAP/SAM)	Qualsiasi documento con pieno valore legale (equivalente firma autografa)

Firme certificate / 2

Tipologia	Conformità normativa	Note sui rischi	Esempi	SLA suggerito
Firma locale con smartcard	FEQ (eIDAS/CAD), se il dispositivo è certificato QSCD	Perdita/furto del dispositivo; PIN scritto o condiviso	Firma di referto/atto singolo alla postazione con lettore smartcard	Revoca/blocco dispositivo entro 24h; cambio PIN secondo policy
Firma remota classica	FEQ (se QTSP e QSCD conformi ETSI/AgID)	Phishing/compromissione secondo fattore; social engineering	Firma singola di contratto/referto con OTP per operazione	Reset credenziali in 4h; OTP time-based; audit giornaliero
Firma remota batch	FEQ (stesse condizioni della remota classica)	Errore di selezione nel lotto; firma indesiderata di documenti inclusi	Firma di un lotto di fatture o referti in un'unica sessione	Verifica contenuto lotto prima della firma; log per lotto; audit 24h
Firma automatica	FEQ (se implementata secondo ETSI EN 419241 e regole AgID)	Uso improprio se deleghe troppo ampie; necessarie policy e audit rigorosi	Emissione massiva di referti/fatture via applicativo integrato	Revisione deleghe settimanale; alert in tempo reale; revoca immediata
Sigillo elettronico qualificato	Sigillo qualificato (eIDAS)	Serve a garantire integrità, provenienza e responsabilità dell'ente, non dell'individuo.	Sigillatura automatica di fatture, attestazioni, certificazioni di sistema	Monitoraggio HSM 24/7; piani di continuità; revoca certificato in 4h
Firma elettronica qualificata (FEQ)	FEQ (eIDAS/CAD)	Rischi e misure dipendono dal modello (locale, remoto, automatico)	N/A (categoria trasversale)	Secondo il modello adottato (locale/remoto/automatico)

Firme non certificate / 1

Tipologia	Titolare	Owner/ Responsabile	Dove sta la chiave	Autenticazione richiesta	Controllo esclusivo	Casi d'uso
Firma Elettronica Avanzata (FEA) – grafometrica	Persona fisica	Utente + IT locale	Nessuna chiave di firma; hash e container cifrato per dati biometrici.	Firma grafometrica su tablet con identificazione visiva e documentale del firmatario.	Garantito tramite raccolta biometrica e identificazione	Consenso informato, accettazione documenti sanitari
Firma Elettronica Avanzata (FEA) – OTP-based	Persona fisica	Utente + IT locale	Nessuna chiave crittografica; OTP generato dinamicamente	User + Password + OTP via SMS/App	Garantito tramite secondo fattore dinamico	Firma documenti in workflow con conferma utente
Firma Elettronica Avanzata (FEA) – biometrica fisica	Persona fisica	Utente + IT locale	Nessuna chiave crittografica; dati biometrici fisici	Impronta digitale o riconoscimento facciale	Garantito tramite identificazione biometrica	Accesso e firma documenti in ambienti protetti
Firma Elettronica Avanzata (FEA) – password-based	Persona fisica	Utente + IT locale	Nessuna chiave crittografica; autenticazione locale	User + Password + PIN statico	Parziale; assente secondo fattore dinamico	Workflow interni con conferma utente

Firme non certificate / 2

Tipologia	Conformità normativa	Note sui rischi	Esempi	SLA suggerito
Firma Elettronica Avanzata (FEA) – grafometrica	FEA (eIDAS/CAD); valida come scrittura privata se conforme	Dipende dalla qualità della raccolta e conservazione biometrica	Firma del paziente su tablet per consenso informato	Verifica dispositivi biometrici; audit mensile; conservazione sicura
Firma Elettronica Avanzata (FEA) – OTP-based	FEA (eIDAS/CAD); valida come scrittura privata se conforme	Phishing sul secondo fattore; OTP intercettato	Firma di contratto con OTP via SMS	OTP time-based; audit settimanale; alert su anomalie
Firma Elettronica Avanzata (FEA) – biometrica fisica	FEA (eIDAS/CAD); valida come scrittura privata se conforme	Falsificazione biometrica; errori di riconoscimento	Firma con impronta digitale su terminale sicuro	Verifica dispositivi biometrici; audit mensile; backup identità
Firma Elettronica Avanzata (FEA) – password-based	FEA (eIDAS/CAD); valida come scrittura privata se conforme	Password condivisa; assenza di secondo fattore	Firma di documenti interni con user/password	Introdurre OTP entro 90 giorni; audit settimanale

Grazie